



PROGRAMA AVANZADO · BLOQUE I — CIBERSEGURIDAD

MÓDULO 2 · GOBERNANZA

Dirección y Gobernanza de la Ciberseguridad

De amenazas a decisiones · Escenario: Telvora Communications

Duración del módulo: 6 h · Gobierno · Riesgo · Regulación · Métricas

Los cinco bloques del módulo

A	 Gobierno	Gobernanza vs gestión, accountability, NIST CSF 2.0, ISO/COBIT/ENS y estrategia
B	 Riesgo	Escenarios, estados del riesgo, apetito, MAGERIT, Open FAIR y BIA
C	 Vulnerability Risk Management	Por qué CVSS no es una cola de parcheo: priorización con contexto
D	 Regulación y gobierno de incidentes	RGPD, ENS, NIS2, AI Act, CRA y respuesta a incidentes 2026
E	 Métricas y prácticas	KPI, KRI, SLA, métricas de vanidad y los dos laboratorios



BLOQUE A



Gobierno

Gobernanza vs gestión · accountability · NIST CSF 2.0 · marcos · estrategia



Gobernar · gestionar · operar · supervisar



Gobernar

Fijar dirección, límites, accountability y supervisión.

Telvora: Dirección: muy baja tolerancia al acceso privilegiado no autorizado.



Gestionar

Planificar y ejecutar dentro de esa dirección.

Telvora: CISO: estrategia, políticas y objetivos.



Operar

Realizar la actividad técnica o de proceso.

Telvora: Arquitectura y Operaciones: PAM, segmentación; SOC monitoriza.



Supervisar

Obtener evidencia independiente de que funciona.

Telvora: Auditoría interna: evalúa el sistema de control.

¿Quién es dueño del riesgo? (no el CISO por defecto)



«Indisponibilidad del servicio B2B de provisión durante más de 4 h por explotación de un gateway remoto.» ¿Quién puede aceptar ese riesgo?



Mala práctica

Risk owner: Cybersecurity

...para todo el registro de riesgos. El CISO no decide si el negocio tolera esa interrupción.



Mejor práctica

Risk owner: Director de Operaciones B2B

Control owner: IAM / Network Security / SOC

Risk facilitator: CISO / Enterprise Risk



Para decisiones críticas, RACI no basta. Deben quedar explícitos: quién decide · quién ejecuta · quién puede parar la operación · quién acepta el riesgo residual · quién es informado · quién guarda la evidencia.

Roles de un modelo de gobierno maduro



Órgano de dirección

Decide prioridades, inversiones y excepciones. No necesita 8.000 CVE.



CISO

Estrategia, políticas y reporting. Independencia para escalar riesgos incómodos.



CIO / CTO / Operaciones

Dueños de activos y controles; no evalúan su propia eficacia sin challenge.



DPO

Protección de datos. No es el CISO: colaboran en brechas y privacy by design.



SOC / CSIRT / DFIR / CTI

Capacidades operativas con rutas de escalado predefinidas.



Legal · Compliance · Comms · BC

Un incidente relevante casi nunca es solo técnico.



Auditoría interna

Opinión independiente: no diseña ni opera lo que evalúa.



La cadena de accountability es tan importante como la tecnología. Cada riesgo necesita un dueño con autoridad; cada control, un responsable; cada excepción, una fecha.

NIST CSF 2.0: GOVERN condiciona a las demás



GOVERN · la gran novedad de 2.0

Contexto · estrategia de riesgo · roles y autoridad · políticas · oversight · supply chain. No es «la parte del CISO».



IDENTIFY

Activos, riesgo y contexto



PROTECT

Salvaguardas y controles



DETECT

Detección de eventos



RESPOND

Contención y respuesta



RECOVER

Restauración y resiliencia



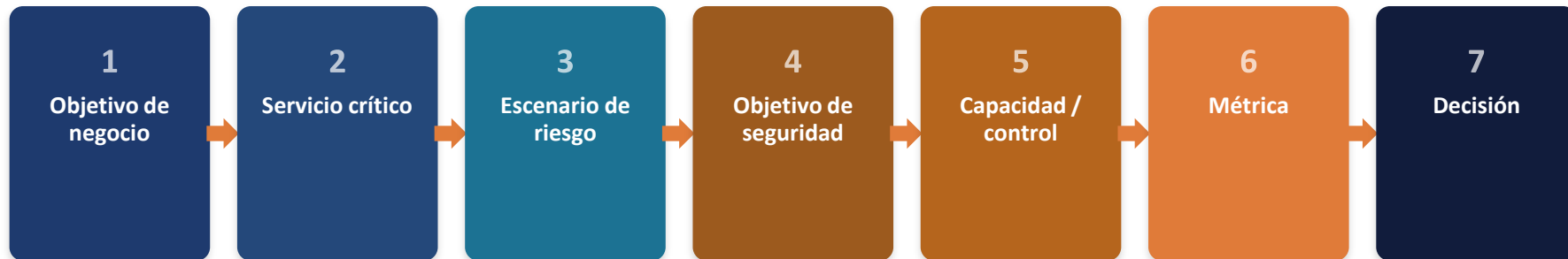
Modelo de outcomes, no checklist: el Core es una taxonomía de resultados; los Profiles (actual vs objetivo) priorizan el gap; los Tiers describen rigor, no son un certificado. La meta es adecuación al contexto.

Cada marco responde una pregunta distinta

	NIST CSF 2.0	¿Qué outcomes necesitamos y cuál es nuestro perfil actual y objetivo?
	ISO/IEC 27001:2022	¿Cómo operamos un sistema de gestión auditable y de mejora continua?
	COBIT 2019	¿Cómo gobernamos I&T alineándola con los objetivos de la empresa?
	ENS (RD 311/2022)	¿Qué obligaciones y medidas aplican a sistemas en su ámbito en España?
	MAGERIT v3	¿Cómo analizamos riesgos de forma estructurada, con dependencias?
	Open FAIR	¿Cómo descomponemos y cuantificamos escenarios de pérdida?

No existe una competición para elegir «el mejor framework»: coexisten y se complementan.

De la estrategia a la decisión, sin eslabones rotos



Si la cadena se rompe, se invierte en controles que no reducen los riesgos prioritarios.



«Necesitamos un SIEM» no es estrategia. Sí lo es: «reducir el tiempo entre el uso no autorizado de una identidad privilegiada y su contención en sistemas de gestión de red». Después se decide si SIEM, EDR, IAM, PAM o segmentación contribuyen al resultado.



BLOQUE B



Riesgo

Escenarios · estados del riesgo · apetito · MAGERIT · Open FAIR · BIA

B

Un riesgo se formula como escenario, no como palabra

Un actor externo obtiene una identidad de proveedor mediante phishing

Actor / fuente

y usa el acceso remoto permitido para alcanzar sistemas de gestión de red

Mecanismo / evento

provocando cambios no autorizados

Activo / servicio

e interrumpiendo el servicio B2B

Consecuencia



Evita entradas como «**Riesgo: ransomware**» · «**Riesgo: CVE-XXXX**» · «**Riesgo: phishing**» — no dicen qué, a quién, ni con qué consecuencia.

Cuatro riesgos que no son sinónimos



Riesgo residual sin evidencia = afirmación, no evaluación. Si una matriz dice «Inherente: Crítico → Residual: Medio» pero nadie explica qué controles producen esa reducción y con qué evidencia de eficacia, ese valor residual no es defendible.

Un control puede estar bien diseñado y no funcionar

Política: MFA obligatoria para todo acceso remoto.



Diseño aparente

Adecuado. Sobre el papel, todos los accesos remotos exigen doble factor.



Efectividad real

- ✗ Dos cuentas de emergencia exentas
- ✗ Usuarios de proveedor fuera del scope
- ✗ Protocolo legacy que no soporta MFA

La efectividad real es inferior a la declarada. Un control existe cuando cubre el escenario, está desplegado, funciona y hay evidencia de ello.

Capacidad · apetito · tolerancia



Capacidad

Máximo riesgo que la organización puede soportar sin poner en peligro su viabilidad o misión.



Apetito

Cantidad y tipo de riesgo que está dispuesta a asumir para alcanzar sus objetivos.



Tolerancia

Variación o límite operativo aceptable alrededor de objetivos concretos.

Telvora — **apetito muy bajo para acceso privilegiado no autorizado a sistemas de gestión de red** se traduce en tolerancias operativas:



0 cuentas privilegiadas compartidas en producción



0 cuentas de terceros permanentes sin owner ni expiración



100 % de accesos privilegiados externos con MFA anti-phishing



excepción máxima de 30 días con aceptación ejecutiva

MAGERIT: el activo vale por lo que sostiene

Servicio de Operación Remota

Servicio de negocio

↓ depende de

NMS-PROD

Sistema de gestión de red

↓ depende de

IAM-CORE + RA-GW01

Identidad + gateway remoto

↓ depende de

Red · DNS · certificados · logs

Infraestructura de soporte



Una salvaguarda reduce riesgo si...

- ✓ existe
- ✓ cubre el escenario
- ✓ está bien desplegada
- ✓ funciona
- ✓ hay evidencia de su eficacia

Si RA-GW01 falla, el impacto no es el valor de una VM: es el servicio que depende de él. Puntuar activos sin entender para qué sirven es un error.

Open FAIR: cuantificar sin falsa precisión

$$\text{Riesgo} \approx \text{Frecuencia de eventos de pérdida} \times \text{Magnitud de la pérdida}$$



Rangos calibrados, no precisión falsa

Pérdida primaria probable: **150k–600k €**

Prob. de pérdida secundaria: **20–50 %**

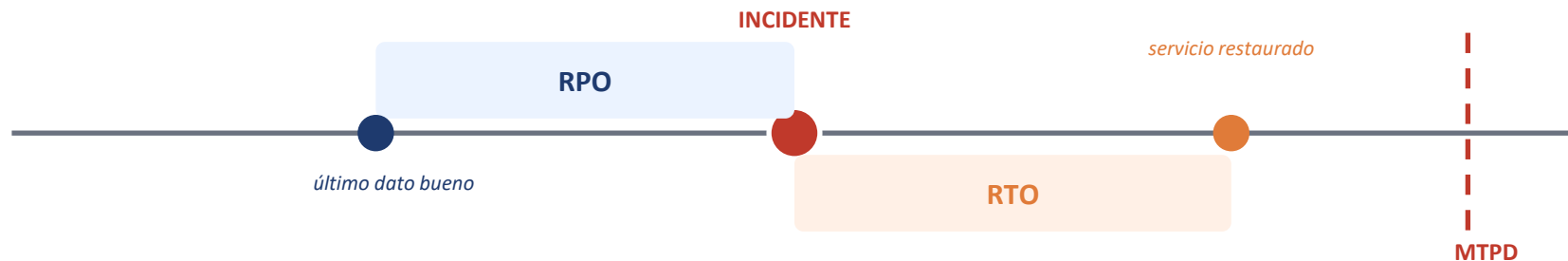
Magnitud secundaria: **250k–2M €**

Cuándo cuantificar

- ✓ Comparar inversiones o tratamientos
- ✓ Justificar controles costosos
- ✓ Evaluar ciberseguros
- ✓ Comunicar en lenguaje financiero

La cuantificación no elimina la incertidumbre: la hace explícita. No es necesario cuantificar cada hallazgo técnico.

BIA: RTO, RPO y periodo máximo tolerable



RPO

Máxima pérdida de datos asumible (punto en el tiempo).



RTO

Tiempo objetivo para restaurar el servicio completo.



MTPD

A partir de aquí las consecuencias son inaceptables.

El RTO debe caer dentro del MTPD con margen. Y un RTO de 2 h no sirve si un proveedor crítico tarda 8 h en activar soporte.



BLOQUE C



Vulnerability Risk Management

Por qué CVSS no es una cola de parcheo · priorización con contexto

CVSS mide severidad técnica, no riesgo de negocio



CVE

Es solo un identificador de una vulnerabilidad pública. No expresa por sí mismo riesgo ni prioridad.



CVSS

Mide severidad técnica. Grupos Base, Threat, Environmental y Supplemental (CVSS-B / BT / BE / BTE).



Idea crítica: CVSS mide severidad técnica, no el riesgo empresarial completo. Un 9.8 en un laboratorio aislado puede importar menos que un 7.5 en un gateway expuesto y explotado.

FIRST recomienda indicar qué grupos se usaron: **CVSS-B** · **CVSS-BT** · **CVSS-BE** · **CVSS-BTE**

Combinar señales: no una, sino todas



CVSS 4.0

Severidad técnica

¿Qué de severa es?



EPSS

Prob. de explotación a 30 días,
actualizada a diario

¿Se explotará pronto?



KEV

Catálogos de vulnerabilidades ya
explotadas

¿Se explota ya en el mundo real?

...y siempre en su contexto:

Exposición / alcanzabilidad

Criticidad del activo/servicio

Threat intelligence

Privilegios requeridos

Controles compensatorios

Impacto de negocio

Restricciones de parcheo

Métrica que sí importa: % de activos críticos Internet-facing con vulnerabilidades explotadas conocidas fuera del SLA de remediación.

¿Cuál corriges primero?

Vulnerabilidad A

9.8

CVSS-B	9.8
Ubicación	lab interno
Ruta desde producción	ninguna
Exploit conocido	no
Estado	se retira en 14 días

Vulnerabilidad B

7.5

CVSS-B	7.5
Ubicación	gateway Internet
PoC público	sí
Explotación activa	sí
Acceso a	servicio crítico

No hay respuesta profesional basada solo en $9.8 > 7.5$. B combina exposición, explotación activa y acceso a servicio crítico: en contexto, gana en prioridad.



BLOQUE D



Regulación y gobierno de incidentes

RGPD · ENS · NIS2 · AI Act · CRA · respuesta y crisis 2026



El mapa normativo de 2026 (España / UE)



RGPD

VIGENTE

Brechas de datos personales: notificación y comunicación.



ENS

VIGENTE

RD 311/2022. Categoriza sistemas: básica, media, alta.



NIS2

EN TRANSPOSICIÓN (ES)

Directiva UE 2022/2555. Gobernanza y reporting de incidentes.



AI Act

APLICACIÓN POR FASES

Aplicación progresiva. Transparencia (art. 50) desde 8-ago-2026.



CRA

RADAR

Reporting (art. 14) aplicable desde 11-sep-2026; pleno en 2027.

Modelo de decisión ante una brecha de datos

Incidente de ciberseguridad

C.I.D de datos personales pueden verse afectadas

¿Es una violación de datos personales?

Distíngela del incidente puramente técnico

¿Probable riesgo para derechos y libertades?

El riesgo relevante es para las PERSONAS

Notificar a la autoridad — 72 h

Sin dilación indebida; la info puede completarse después

¿Alto riesgo? → comunicar a los afectados

Sin dilación indebida, además de a la autoridad



72 h

desde que se tiene constancia



El riesgo que decide la comunicación es el de las personas, no el reputacional de Telvora.

NIS2: precisión sobre el estado real en España

Estado de la transposición

● 17-oct-2024

Fecha límite de transposición de la Directiva (UE) 2022/2555.

● 8-jul-2026

La Comisión decide llevar a España (con IE, FR y NL) ante el TJUE por no notificar la transposición completa.

● 14-ene-2025

Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad. NO es aún ley vigente.

● Vigente hoy

Sigue aplicando el RD-ley 12/2018 y el RD 43/2021, más normativa sectorial.

Art. 20 — Gobernanza

La dirección aprueba las medidas de riesgo, supervisa su implantación y recibe formación. La ciberseguridad pasa a ser cuestión de governance.

Art. 23 — Reporting de incidentes significativos

≤ 24 h

early warning

≤ 72 h

notificación

≤ 1 mes

informe final



No mezclar con las 72 h del RGPD. Distinto sujeto, criterio, finalidad y autoridad.

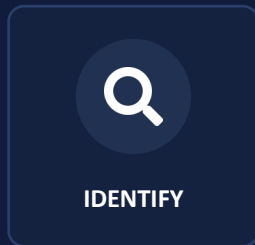
NIST SP 800-61r3: la respuesta no empieza en la alerta

Rev. 3 (abril 2025) integra la respuesta a incidentes dentro de la gestión del riesgo y del NIST CSF 2.0.

PREPARACIÓN DISTRIBUIDA



GOVERN

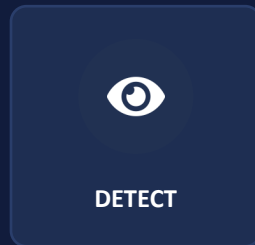


IDENTIFY



PROTECT

NÚCLEO OPERATIVO DE RESPUESTA



DETECT



RESPOND



RECOVER



La mejora continua retroalimenta todas las funciones.



La respuesta empieza mucho antes de la alerta: inventario, arquitectura, logging, contratos, roles, backups, comunicación, formación, threat intelligence y ejercicios.

De incidente a crisis: roles y decision log



Incident Commander

Coordina decisiones y visión global. No hace el análisis técnico.



Technical Lead

Dirige investigación, contención y recuperación técnica.



Scribe / Decision log

Registra decisiones: hora, hechos, alternativas, dueño y motivo.



DPO / Legal / Compliance

Entran por criterios predefinidos, no en el último minuto.



Business owner

La contención tiene consecuencias: valora ambos lados.

Niveles de decisión

Táctica: bloquear una IP

Operacional: aislar un segmento de red

Estratégica: parar un servicio crítico 2 h para frenar la intrusión

El incidente es crisis cuando...

- ✓ afecta a un servicio crítico
- ✓ hay riesgo para personas
- ✓ se pierde control operacional
- ✓ hay interés regulatorio o mediático
- ✓ exige dirección ejecutiva



BLOQUE E



Métricas y prácticas

KPI · KRI · SLA · métricas de vanidad · laboratorios

E

KPI · KRI · SLA (y el peligro de las medias)



KPI

Desempeño frente a un objetivo.

Ej.: % de incidentes críticos con Incident Commander en plazo



KRI

Exposición o deterioro del riesgo.

Ej.: nº de cuentas privilegiadas sin owner; excepciones vencidas



SLA

Compromiso de nivel de servicio.

Ej.: crítico + explotación + Internet-facing → 24 h para decidir



MTTD / MTTR: cuidado con la media. Una media oculta las colas: pregunta también por la mediana, el percentil 90/95, la severidad y el tipo de incidente. Reducir el MTTR cerrando alertas como falsos positivos no mejora la seguridad.

SOC moderno: lo importante no es cuántos «tiers» hay, sino si existe una cadena eficiente desde la señal hasta la decisión y la mejora.

Métricas de vanidad: impresionan, no informan



«Bloqueamos 3 millones de ataques»



«Cerramos 12.000 vulnerabilidades»



«El SOC procesó 50.000 alertas»



«Formamos al 100 % de la plantilla»

Las preguntas que desinflan la vanidad



¿Qué denominador existe?



¿Qué outcome mejoró?



¿Qué riesgo se redujo?



¿Cómo se sabe?



¿Qué quedó fuera?



¿Qué tendencia hay?

Laboratorios: decidir sobre el riesgo de Telvora



Lab 2.1

Risk Decision Board

Convertir el Threat Brief en escenarios de riesgo, aplicar MAGERIT simplificado, estimar impacto y decidir tratamiento con dueño y evidencia.

Objetivo: una decisión de riesgo defendible, no una tabla de colores.



Lab 2.2

Breach & Crisis Tabletop

Ejercicio con injects progresivos (T0→T6), roles, información incompleta, decision log y reloj regulatorio corriendo.

Objetivo: mantener facts, hipótesis, decisiones y dueños bajo presión.

El cambio de mentalidad del módulo



Gobernar ≠ gestionar ≠ operar ≠ supervisar

Y el riesgo tiene un dueño con autoridad, no el CISO por defecto.



CVSS ≠ prioridad

Priorizas con exposición, explotación y contexto de negocio.



RGPD 72 h ≠ NIS2 72 h

Distinto sujeto, criterio, finalidad y autoridad.



Diseño ≠ eficacia del control

Residual sin evidencia es una afirmación, no una evaluación.



Actividad ≠ reducción de riesgo

Desconfía del número grande sin denominador ni tendencia.



Marco correcto ≠ decisión correcta

La pregunta es qué decisión tomamos y quién acepta lo que queda.



✓ MÓDULO 2 COMPLETADO

A continuación

Módulo 3 — Arquitecturas de Ciberseguridad

- Diseño seguro: mínimo privilegio, segmentación, Zero Trust
- Modelos de referencia: SABSA, TOGAF, NIST SP 800-207
- NGFW, IDS/IPS, WAF, SIEM, SOAR, EDR/XDR
- Seguridad en nube, contenedores y DevSecOps

«Si este es nuestro riesgo prioritario, ¿qué arquitectura deberíamos diseñar?»